

Actividad 01



Curso Ethical Hacking

Margenys Guedez

Hacker Women Council

ACTIVIDAD 01 – Análisis y planificación de Pentest a Aurora Market.

Participante: Margenys Basha Guedez Perez.

Programa: Hacker Women Council – Ethical Hacking.

Caso: Aurora Market.

Punto N°1: OBJETIVO DEL PENTEST

1. Identificar vulnerabilidades que puedan comprometer los datos (exposición de datos, permitir accesos no autorizados y manipulación de información) o funciones de Aurora Market.
2. Evaluar autenticación, sesiones y permisos de los diferentes usuarios para asegurar que el usuario solo pueda realizar acciones de acuerdo a su rol/perfil).
3. Analizar y determinar si el problema reportado por el usuario corresponde realmente a una vulnerabilidad y valorar su impacto.

Punto N°2: ALCANCE

1. Lo que si se evaluará:
 - ✓ Aplicación web de la empresa.
 - ✓ Mecanismo de inicio de sesión y autenticación.
 - ✓ Funcionalidades visibles y accesibles desde la plataforma.
 - ✓ Todos los roles, permisos y tipos de usuarios.
 - ✓ Interacción de la aplicación con la base de datos.
 - ✓ Manejo de datos enviados por los usuarios.
 - ✓ Comportamiento relacionado con el problema reportado inicialmente.
2. Lo que no se evaluará:
 - Sistemas pertenecientes a terceros.
 - Servicios externos que no pertenezcan a Aurora Market y que esten o no conectados con la Aplicación web.
 - Ingeniería social contra empleados o clientes.
 - Ataques de denegación de servicio que puedan afectar la disponibilidad del sitio.
 - Instalaciones físicas de la empresa.
 - Dispositivos personales de trabajadores o clientes.
 - Sistemas o direcciones que no hayan sido incluidos expresamente en la autorización.
 - Extracción, modificación o eliminación deliberada de información real.

Punto N°3: AUTORIZACIÓN Y CONDICIONES

Permisos requeridos:

- Autorización expresa y escrita de Aurora Market para realizar las pruebas/investigación sobre la aplicación web y mecanismos de autenticación.
- Identificación clara de los sistemas y dominios permitidos por la compañía.
- Definición de las cuentas de usuario de prueba que podrán usarse durante la evaluación.
- Autorización para intentar validar las vulnerabilidades encontradas dentro de los límites controlados.
- Identificación de matriz de escalamiento de Aurora Market en caso de que suceda o se descubra un incidente real.

Condiciones acordadas:

- ✓ Las pruebas solo se realizarán a los activos incluidos en el alcance, por tanto solo será a la aplicación web de Aurora Market.
- ✓ No se realizarán acciones que puedan interrumpir el servicio en ningún horario.
- ✓ No se eliminarán ni modificarán datos reales de clientes ni de la empresa.
- ✓ La explotación se limitará a lo estrictamente necesario para comprobar la existencia de una vulnerabilidad y se realizará en horario de baja demanda.
- ✓ Si se encuentra una vulnerabilidad crítica que pueda afectar el funcionamiento de la plataforma, se notificará de inmediato a la matriz de escalamiento.
- ✓ Toda la información del pentest será tratada como confidencial.
- ✓ Los hallazgos se documentarán con evidencia suficiente para que el equipo de desarrollo del cliente pueda revisarlos posteriormente.

Punto N°4: TIPO DE PENTEST

- ✓ Tipo de pentest elegido: GRAY-BOX
- ✓ Justificación: Se selecciona Gray-box porque el equipo recibe información parcial sobre Aurora Market. Se conoce que existe una aplicación web, una base de datos, autenticación y diferentes usuarios, pero se desconoce una buena parte de la arquitectura y de las tecnologías utilizadas. Esto permite evaluar la plataforma desde una situación bastante cercana a la que podría tener un atacante con cierto conocimiento previo o incluso contando con el acceso como usuario legítimo.

Punto N°5: PLANIFICACIÓN

Antes de comenzar con el ejercicio, es necesario cumplir lo siguiente:

1. Objetivos:
 - ✓ Identificar vulnerabilidades.
 - ✓ Validar autenticaciones y autorizaciones.
 - ✓ Analizar el problema reportado por el usuario.
2. Alcance:
 - ✓ Aplicación web, autenticación, usuarios, sesiones, control de acceso y componentes directamente relacionados y autorizados por Aurora Market; sin exceptuar las condiciones acordadas del punto 3.
3. Permisos y condiciones:
 - ✓ Autorización expresa y escrita para realizar la evaluación.
 - ✓ Activos permitidos, definición de horario de pruebas y límites técnicos.
 - ✓ Cuentas disponibles autorizadas.
 - ✓ Flujo de tratamiento de información y matriz de escalamiento con el contacto de emergencia.
4. Metodología a utilizar:
 - ✓ Metodología estructurada de pentesting, complementada por OWASP.

5. Recopilación de información previa:
 - ✓ Dominios autorizados, funcionalidades principales, cuentas de prueba, tipos de usuarios, comportamiento reportado y evidencia del mismo en caso de tenerla; toda la documentación que Aurora Market pueda facilitar.
6. Recursos necesarios:
 - ✓ Equipo de pruebas, cuentas de prueba validadas y sistema para salvaguardar evidencias, navegador, proxy de análisis web, herramientas de reconocimiento y análisis de vulnerabilidades (ejemplo Who.is)
7. Programación del pentest:
 - ✓ Definir fecha de inicio y fin.
 - ✓ Horario autorizado para las pruebas específico.
 - ✓ Responsables directos por parte cliente.
 - ✓ Tiempo de análisis.
 - ✓ Fecha de entrega del informe.

Punto N°6: FASES DEL PENTEST

A continuación, se describe lo que se buscaría en cada etapa del ejercicio.

1. Reconocimiento
 - ✓ Recopilar información sobre Aurora Market y su aplicación sin intentar explotar nada.
 - ✓ Conocer la estructura pública del sitio, funcionalidades disponibles, páginas de autenticación, formularios, áreas de usuario y demás elementos accesibles desde el exterior.
 - ✓ Revisar qué información podría obtener un atacante con los datos que ya tiene disponibles.
2. Análisis de vulnerabilidades
 - ✓ Con la información obtenida, se revisan los posibles puntos débiles de la aplicación como autenticación, control de acceso, gestión de sesiones, exposición innecesaria de información, configuración de seguridad, tratamiento de datos ingresados por el usuario, interacción de la aplicación con sus datos.
 - ✓ Revalidar manualmente los resultados obtenidos con la herramienta de escaneo para evitar falsos positivos y documentar los hallazgos, lo cual va conectado con la explotación.
3. Explotación
 - ✓ Las vulnerabilidades identificadas se validarían de manera controlada, el objetivo no es provocar daños, sino comprobar si el problema realmente puede aprovecharse y cual sería su consecuencia.
 - ✓ Las pruebas se detienen una vez se cuente con la evidencia suficiente para documentar el hallazgo.
4. Post-explotación
 - ✓ Si se logra demostrar una vulnerabilidad, se evaluará hasta dónde podría llegar un atacante aprovechándola, pero sin afectar información real. Aquí interesa determinar principalmente: qué información podría quedar expuesta; qué permisos podrían obtenerse; si otros usuarios podrían verse afectados; si sería posible avanzar hacia otras partes de la plataforma; cuál sería el impacto sobre confidencialidad, integridad o disponibilidad (Tríada CIA).
 - ✓ Después de las pruebas se debe comprobar que no se haya dejado cambios, archivos, sesiones o configuraciones derivados de la evaluación.

5. Informe

- ✓ Documentación de cada vulnerabilidad encontrada, cada hallazgo incluiría: nombre del hallazgo, descripción, componente afectado, evidencia, riesgo, posible impacto, forma general de reproducción y recomendación de corrección.
- ✓ Incluye un resumen ejecutivo explicativo para Aurora Market, indicando cuales son los principales riesgos encontrados y cuales deben solucionarse primero.

Punto N°7: INVESTIGACIÓN

- ✓ Metodología elegida: OWASP, porque proporciona una guía específica y estructurada para evaluar aplicaciones web como Aurora Market.
- ✓ ¿Por qué será útil para este proyecto?
Porque Aurora Market funciona mediante una aplicación web y OWASP WSTG ofrece una guía específica para evaluar este tipo de sistemas. Permite organizar pruebas de autenticación, sesiones, autorización, validación de datos y lógica de negocio, que son elementos importantes dentro del escenario.